S8 AGENT SANDBOXING DETAILS

We provide the sandboxing details for the optimizer and detector agents. This section lists the restrictions summarized in Sec. 3.

S8.1 OPTIMIZER AGENT

Claude Code optimizer.

- **Working directory:** The optimizer starts in its own per-iteration workspace, `workspaces/opt_<session>_iter<N>_optimizer/`.
- **No file writes or edits:** The Write and Edit tools are denied, since headless mode has no one to approve them.
- **Read tool limited to the workspace:** Reading any file outside the workspace requires approval, so it is denied.
- **`find` and `grep` limited to the workspace:** Running these commands on folders outside the workspace is blocked.
- **Shell commands:** Every shell command requires approval, except read-only commands and `python3`.
- **Non-interactive:** The optimizer runs as a single `-p` call with no approval prompts, so every permission request is denied.
- **Fixed system prompt:** Our `OPTIMIZER_SYSTEM` prompt replaces Claude Code's default system prompt.
- **Subscription auth only:** `ANTHROPIC_API_KEY` is removed from the optimizer's environment.
- **Time limit:** Each call is bounded by `runner.timeout_s`.
- **Output:** Only the optimizer's final message is used as the new harness.
- **Validation:** The new harness must keep the SCoT scaffold and the verdict schema; otherwise, the iteration counts as failed.
- **Input:** The optimizer sees only the current workspace's trajectory (harnesses, metrics, history, and labeled predictions). PrimeVul is never copied into the workspace.

Codex optimizer.

- **Working directory:** The optimizer runs in its own per-iteration workspace (`--cd <workspace>`).
- **OS sandbox:** The optimizer runs under the `benchmark_readonly` permission profile, which gives it read-only access to the workspace and to minimal system runtime paths, no other filesystem access, and no write access anywhere.
- **No network:** Network access is disabled in the permission profile.
- **No web search:** Web search is disabled.
- **No approvals:** `approval_policy` is set to `"never"`, so the optimizer cannot escalate its permissions.
- **Isolated setup:** Each call uses a fresh temporary Codex home with only the auth file copied in, so no user config, skills, MCP servers, or memories are loaded.
- **No instruction files:** `AGENTS.md` and other project docs are disabled (`project_doc_max_bytes = 0`).
- **No sub-agents:** Sub-agents are disabled (`multi_agent = false`).
- **Ephemeral session:** Each session is ephemeral (`--ephemeral`), and the Codex rules files are ignored (`--ignore-rules`).
- **Time limit:** Each call is bounded by `runner.timeout_s`.

- **Output:** Only the optimizer's final message is used as the new harness, and it goes through the same SCoT and schema validation.
- **Input:** The optimizer sees only the current workspace's trajectory (harnesses, metrics, history, and labeled predictions). PrimeVul is never copied into the workspace.

S8.2 Detection Agent (Evaluator)

Claude Code detection agent.

- **No tools:** The detector runs with no tools (`--tools ""`), so it cannot read files or run commands.
- **Empty system prompt:** The detector runs with an empty system prompt (`--system-prompt ""`).
- **Working directory:** The detector runs from `/tmp`, so it has no workspace and no repository instructions.
- **Fresh process per function:** Each function is evaluated in a new process, so nothing is remembered between calls.
- **Input:** The detector receives only the rendered harness with one function. It never sees labels, the trajectory, or metrics.
- **Time limit:** Each call is bounded by `runner.timeout_s`.

Codex detection agent.

- **Working directory:** Each function is evaluated in an empty temporary directory, created fresh for that call.
- **OS sandbox:** The detector runs under the same `benchmark_readonly` sandbox, so it is read-only, cannot write, and has no network access.
- **Other restrictions:** Web search is disabled, and the detector has no approvals, sub-agents, instruction files, user config, skills, MCP servers, or memories.
- **Ephemeral session:** Each function gets an ephemeral session and a fresh temporary Codex home.
- **Input:** The detector receives only the rendered harness with one function. It never sees labels, the trajectory, or metrics.
- **Time limit:** Each call is bounded by `runner.timeout_s`.

S8.3 Workspace-Level Restrictions

These restrictions apply to all runs.

- **Separate workspaces:** The optimizer's workspace (suffix `_optimizer`) contains labels and is kept separate from any evaluator copy, which has its labels stripped (`_copy_predictions_no_labels`).
- **Validation data only:** PrimeVul data and predictions are never placed in any workspace.
- **Fixed model weights:** Only the harness text changes between iterations; the model weights stay fixed.